

KYC Orchestration Service — API Reference

Base URL: http://<host>:8086

Content-Type: application/json

Service Name (Eureka): kyc-orchestration

Table of Contents

- [1. POST /api/v1/kyc/initiate](#)
- [2. GET /api/v1/kyc/{kycId}/status](#)
- [3. PATCH /api/v1/orchestration/{kycId}/status](#)
- [4. Webhook Notifications](#)
- [5. Data Dictionaries](#)
- [6. Error Responses](#)
- [7. End-to-End Flows](#)
- [8. Architecture & Security Notes](#)

1. POST /api/v1/kyc/initiate

Initiates a KYC pre-check for a new client. KYC Orchestration concurrently invokes the KYC-NCA data ingestion and NLS real-time screening, then sequentially requests a CRRE risk rating. The consolidated result is returned synchronously.

If the screening returns a Hit or the risk rating is **HIGH**, onboarding is placed **on hold** and `kycStatus` in the response will be `ON_HOLD`. The invoker must retain the `kycId` to query or receive the updated status later.

Request

```
POST /api/v1/kyc/initiate
Content-Type: application/json
```

Request Body

Core Identity

Field	Type	Required	Description
uniqueClientID	string	Yes	Unique identifier for the client provided by EIS/PPR Gateway. Primary correlation key across all downstream calls.
firstName	string	Yes	Client's first name. Stored AES-GCM encrypted at rest.
middleName	string	No	Client's middle name.
lastName	string	Yes	Client's last name. Stored AES-GCM encrypted at rest.
title	string	No	Client's title (e.g. Mr, Ms, Dr).
dob	string	Yes	Date of birth. Stored AES-GCM encrypted at rest. Recommended format: YYYY-MM-DD.
businessLine	string	Yes	Originating business line. Must be exactly EIS or PPR.

Biographical / Citizenship

Field	Type	Required	Description
-------	------	----------	-------------

cityOfBirth	string	Yes	City of birth.
countryOfBirth	string	No	Country of birth (ISO 3166-1 alpha-2 recommended, e.g. DE).
primaryCitizenship	string	Yes	Primary citizenship country code.
secondCitizenship	string	No	Second citizenship country code, if applicable.
clientAdoptionCountry	string	No	Country where the client was adopted/onboarded (ISO 3166-1 alpha-2, e.g. DE). Forwarded to CRRE as a risk input.
countryOfDomicile	string	No	Country of domicile (ISO 3166-1 alpha-2, e.g. CH). May differ from country of residence. Forwarded to CRRE.
investorVisa	boolean	No	true if the client holds an investor visa. Defaults to false. Forwarded to CRRE as an additional risk flag.

Residential Address — nested object `residentialAddress`

Field	Type	Required	Description
<code>residentialAddress</code>	object	Yes	Nested address object. All sub-fields validated independently.
<code>residentialAddress.addressLine1</code>	string	Yes	Street address line 1. Stored AES-GCM encrypted at rest.
<code>residentialAddress.addressLine2</code>	string	No	Street address line 2. Stored AES-GCM encrypted at rest when present.
<code>residentialAddress.city</code>	string	Yes	City.
<code>residentialAddress.zip</code>	string	Yes	Postal / ZIP code.
<code>residentialAddress.validFrom</code>	string	No	Date from which this address is valid (YYYY-MM-DD). Forwarded to CRRE as a geo-risk input (<code>residentialAddressValidFrom</code>).
<code>countryOfResidence</code>	string	Yes	Country of residence (ISO 3166-1 alpha-2 recommended, e.g. DE).

Occupation

Field	Type	Required	Description
<code>occupation</code>	string	No	Client's occupation or job title.

Legitimation Document

Field	Type	Required	Description
<code>typeOfLegitimizationDocument</code>	string	No	Document type (e.g. PASSPORT, NATIONAL_ID, DRIVING_LICENCE).
<code>issuingAuthority</code>	string	No	Name of the authority that issued the document.
<code>identificationNumber</code>	string	No	Document identification number. Stored AES-GCM encrypted at rest.
<code>expirationDate</code>	string	No	Document expiry date. Recommended format: YYYY-MM-DD.

Tax Identifier

Field	Type	Required	Description
germanTaxID	string	No	German tax identification number (<i>Steuer-IdNr</i>). Stored AES-GCM encrypted at rest.

Webhook

Field	Type	Required	Description
webhookUrl	string	No	If provided, KYC Orchestration will POST the final KycStatusResponse to this URL when the KYC status transitions out of ON_HOLD. See Webhook Notifications .

Example Request

```
{
  "uniqueClientID": "CLIENT-20260411-00123",
  "firstName": "Jane",
  "middleName": "Marie",
  "lastName": "Smith",
  "title": "Ms",
  "dob": "1985-06-15",
  "businessLine": "EIS",
  "cityOfBirth": "Hamburg",
  "countryOfBirth": "DE",
  "primaryCitizenship": "DE",
  "secondCitizenship": "US",
  "clientAdoptionCountry": "DE",
  "countryOfDomicile": "CH",
  "investorVisa": false,
  "residentialAddress": {
    "addressLine1": "Unter den Linden 1",
    "addressLine2": "Apt 4B",
    "city": "Berlin",
    "zip": "10117",
    "validFrom": "2022-03-01"
  },
  "countryOfResidence": "DE",
  "occupation": "Software Engineer",
  "typeOfLegitimizationDocument": "PASSPORT",
  "issuingAuthority": "Bundesdruckerei",
  "identificationNumber": "C01X00T47",
  "expirationDate": "2030-08-15",
  "germanTaxID": "86095742719",
  "webhookUrl": "https://eis-gateway.internal/api/kyc/callbacks/status"
}
```

Response

HTTP 200 OK

Response Body

Field	Type	Description
-------	------	-------------

kycId	string (opaque)	Unique identifier for this KYC lifecycle. Retain this to call the status endpoint or match incoming webhook notifications. The value is an opaque, non-sequential string — it does not reveal any information about record volume or creation order.
kycStatus	string	APPROVED — onboarding can proceed. ON_HOLD — screening hit or high risk; KYC review required.
screeningResult	string	Raw screening outcome: Hit or NoHit.
hitContext	array<string>	Context types for a Hit (e.g. ["PEP"], ["PEP", "ADM"]). Empty array when NoHit.
riskRating	string	CRRE risk rating: LOW, MEDIUM, HIGH, or UNKNOWN.
userId	string	User ID assigned by KYC-NCA ingestion. May be null if ingestion failed (non-fatal).
screeningRequestId	string (UUID)	Traceability ID for the NLS/NRTS screening call.
riskRequestId	string (UUID)	Traceability ID for the CRRE risk rating call.
screeningStartAt	string (ISO-8601)	Timestamp when screening was initiated.
screeningEndAt	string (ISO-8601)	Timestamp when screening result was received.
riskStartAt	string (ISO-8601)	Timestamp when risk rating was initiated.
riskEndAt	string (ISO-8601)	Timestamp when risk rating result was received.

Example Response — Approved (no hit, low risk)

```
{
  "kycId": "x3Yq9mZ1",
  "kycStatus": "APPROVED",
  "screeningResult": "NoHit",
  "hitContext": [],
  "riskRating": "LOW",
  "userId": "usr-7f3a1c2d",
  "screeningRequestId": "scr-a1b2c3d4-e5f6",
  "riskRequestId": "rsk-f6e5d4c3-b2a1",
  "screeningStartAt": "2026-04-11T10:00:00.123",
  "screeningEndAt": "2026-04-11T10:00:00.456",
  "riskStartAt": "2026-04-11T10:00:00.457",
  "riskEndAt": "2026-04-11T10:00:00.789"
}
```

Example Response — On Hold (PEP hit)

```
{
  "kycId": "nR7kW2pL",
  "kycStatus": "ON_HOLD",
  "screeningResult": "Hit",
```

```
"hitContext": ["PEP"],
"riskRating": "HIGH",
"userId": "usr-a4b5c6d7",
"screeningRequestId": "scr-b2c3d4e5-f6a7",
"riskRequestId": "rsk-a7f6e5d4-c3b2",
"screeningStartAt": "2026-04-11T10:01:00.100",
"screeningEndAt": "2026-04-11T10:01:00.380",
"riskStartAt": "2026-04-11T10:01:00.381",
"riskEndAt": "2026-04-11T10:01:00.650"
}
```

What to Do When `ON_HOLD`

When `kycStatus` is `ON_HOLD` :

1. **Store the `kycId`** — you will need it for the status endpoint or to match incoming webhook notifications.
2. **Notify your end user** that onboarding is pending KYC review.
3. **Await notification via one of two mechanisms:**
 - **Webhook (recommended):** If you supplied a `webhookUrl` , KYC Orchestration will push the update to you automatically when the status changes. No polling required.
 - **Polling:** Call `GET /api/v1/kyc/{kycId}/status` periodically until `kycStatus` changes to `APPROVED` or `COMPLETED` .

2. GET `/api/v1/kyc/{kycId}/status`

Retrieves the current KYC status by ID. Use this endpoint to poll for updates when a `webhookUrl` was not provided, or to confirm state at any time.

Request

```
GET /api/v1/kyc/{kycId}/status
```

Path Parameters

Parameter	Type	Required	Description
<code>kycId</code>	string (opaque)	Yes	The <code>kycId</code> returned by <code>POST /api/v1/kyc/initiate</code> .

Example Request

```
GET /api/v1/kyc/nR7kW2pL/status
```

Response

HTTP 200 OK

Response Body

Field	Type	Description
<code>kycId</code>	string (opaque)	The KYC identifier.
<code>uniqueClientId</code>	string	The client identifier originally supplied in the initiation request.
<code>businessLine</code>	string	EIS or PPR.

kycStatus	string	Current KYC status. See KycStatus .
screeningStatus	string	HIT or NO_HIT. null if still PENDING.
screeningContext	array<string>	Context types for a HIT (e.g. ["PEP"]). Empty when NO_HIT or PENDING.
riskRating	string	LOW, MEDIUM, HIGH, or UNKNOWN. null if still PENDING.
screeningRequestId	string	NLS/NRTS traceability ID.
riskRequestId	string	CRRE traceability ID.
createdAt	string (ISO-8601)	When the KYC record was first created.
updatedAt	string (ISO-8601)	When the KYC record was last updated.

Example Response

```
{
  "kycId": "nR7kW2pL",
  "uniqueClientId": "CLIENT-20260411-00123",
  "businessLine": "EIS",
  "kycStatus": "ON_HOLD",
  "screeningStatus": "HIT",
  "screeningContext": ["PEP"],
  "riskRating": "HIGH",
  "screeningRequestId": "scr-b2c3d4e5-f6a7",
  "riskRequestId": "rsk-a7f6e5d4-c3b2",
  "createdAt": "2026-04-11T10:01:00.000",
  "updatedAt": "2026-04-11T10:01:01.234"
}
```

Not Found

If the `kycId` does not exist:

HTTP 404 Not Found

```
{
  "timestamp": "2026-04-11T10:05:00.000",
  "status": 404,
  "error": "Not Found",
  "message": "KYC record not found for id: nR7kW2pL"
}
```

Polling Guidance

kycStatus	Meaning	Action
PENDING	Downstream calls still in progress	Retry after a short interval
APPROVED	Clean pass — no hit, low/medium risk	Proceed with onboarding
ON_HOLD	KYC review in progress	Continue polling or await webhook
COMPLETED	KYC-NCA review finalised	Read screeningStatus + riskRating for final outcome

Recommended polling interval: **30 seconds**. Maximum polling window is determined by your agreed SLA with the KYC Platform team.

3. PATCH /api/v1/orchestration/{kycId}/status

Internal endpoint — intended for KYC-NCA callback only. Not part of the EIS/PPR Gateway integration.

Transitions the KYC record to a final status once KYC-NCA review is complete. After a successful update, KYC Orchestration asynchronously fires a webhook to the EIS/PPR Gateway if a `webhookUrl` was registered at initiation.

Request

```
PATCH /api/v1/orchestration/{kycId}/status
Content-Type: application/json
```

Path Parameters

Parameter	Type	Required	Description
kycId	string (opaque)	Yes	The KYC record to update.

Request Body

Field	Type	Required	Description
kycStatus	string	Yes	Target status. Must be APPROVED or COMPLETED.

Example Request

```
{
  "kycStatus": "COMPLETED"
}
```

Response

HTTP 200 OK — returns the updated `KycStatusResponse` (same schema as `GET /api/v1/kyc/{kycId}/status`).

Validation Rules

Condition	HTTP Status	Error
kycStatus is PENDING or ON_HOLD	400 Bad Request	Invalid target status
Record is already COMPLETED	409 Conflict	Cannot update a completed KYC record
kycId not found	404 Not Found	Record not found

4. Webhook Notifications

When `webhookUrl` is supplied at initiation and the KYC status is `ON_HOLD` , KYC Orchestration will `POST` to that URL when the status is updated via the `PATCH` endpoint.

Delivery Behaviour

Property	Value
----------	-------

Method	POST
Content-Type	application/json
Idempotency Header	X-KYC-Id: <kycId>
Retries	3 attempts with exponential back-off (1 s → 2 s → 4 s)
On exhaustion	Event is dead-lettered to KYC Orchestration error log for ops alerting
Threading	Fully async — never blocks the PATCH response

Webhook Payload

The body is identical to the `GET /api/v1/kyc/{kycId}/status` response:

```
{
  "kycId": "nR7kW2pL",
  "uniqueClientId": "CLIENT-20260411-00123",
  "businessLine": "EIS",
  "kycStatus": "COMPLETED",
  "screeningStatus": "HIT",
  "screeningContext": ["PEP"],
  "riskRating": "HIGH",
  "screeningRequestId": "scr-b2c3d4e5-f6a7",
  "riskRequestId": "rsk-a7f6e5d4-c3b2",
  "createdAt": "2026-04-11T10:01:00.000",
  "updatedAt": "2026-04-11T14:32:00.000"
}
```

Webhook Implementation Requirements (EIS/PPR Gateway)

- Expose an HTTPS endpoint that accepts `POST` with `Content-Type: application/json`.
- Return `HTTP 2xx` to acknowledge receipt. Any non-2xx is treated as a failure and triggers a retry.
- Use the `X-KYC-Id` header to deduplicate deliveries in case of retries.
- Respond within **5 seconds** to avoid timeout-triggered retries. Process the payload asynchronously.

5. Data Dictionaries

KycStatus

Value	Description
PENDING	KYC record created; downstream calls in flight. Transient — should not persist for more than a few seconds.
APPROVED	Screening returned no hit and risk is not HIGH. Onboarding can proceed immediately.
ON_HOLD	Screening returned a Hit or risk is HIGH. Onboarding is suspended pending KYC analyst review.
COMPLETED	KYC-NCA review is complete and a final decision has been communicated.

ScreeningStatus

Value	Description
HIT	NLS/NRTS matched one or more entries. See <code>screeningContext</code> for match types.

NO_HIT	NLS/NRTS found no matches.
--------	----------------------------

ScreeningContext Values (Non-Exhaustive)

Value	Meaning
PEP	Politically Exposed Person
ADM	Adverse Media
SAN	Sanctions list match

RiskRating

Value	Description
LOW	Low risk — no action beyond standard onboarding.
MEDIUM	Medium risk — subject to enhanced due diligence per policy.
HIGH	High risk — triggers ON_HOLD and mandatory KYC review.
UNKNOWN	CRRE response was unavailable or unparseable. Treat as HIGH for safety.

6. Error Responses

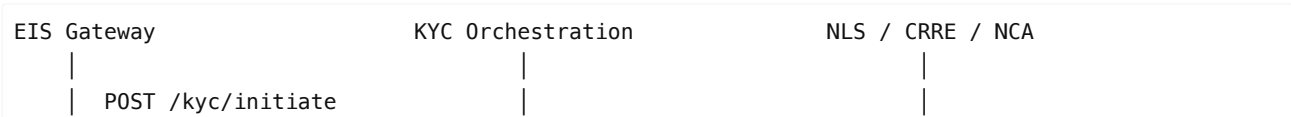
All errors follow a consistent structure:

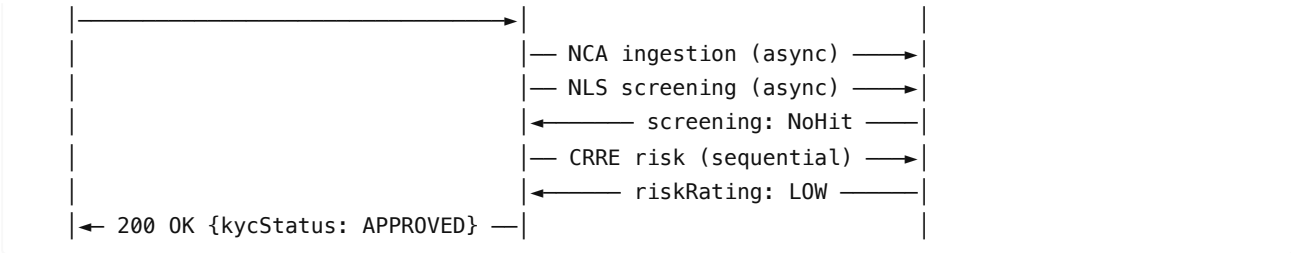
```
{
  "timestamp": "2026-04-11T10:05:00.000",
  "status": 400,
  "error": "Validation Failed",
  "message": "businessLine: businessLine must be EIS or PPR; dob: dob is required"
}
```

HTTP Status	Trigger
400 Bad Request	Validation failure on request body (missing required fields, invalid businessLine, invalid kycStatus on PATCH)
404 Not Found	kycId does not exist
409 Conflict	Attempting to update a KYC record already in COMPLETED state
502 Bad Gateway	A downstream service (NLS, CRRE, KYC-NCA) returned an error
500 Internal Server Error	Unexpected error in the orchestration service

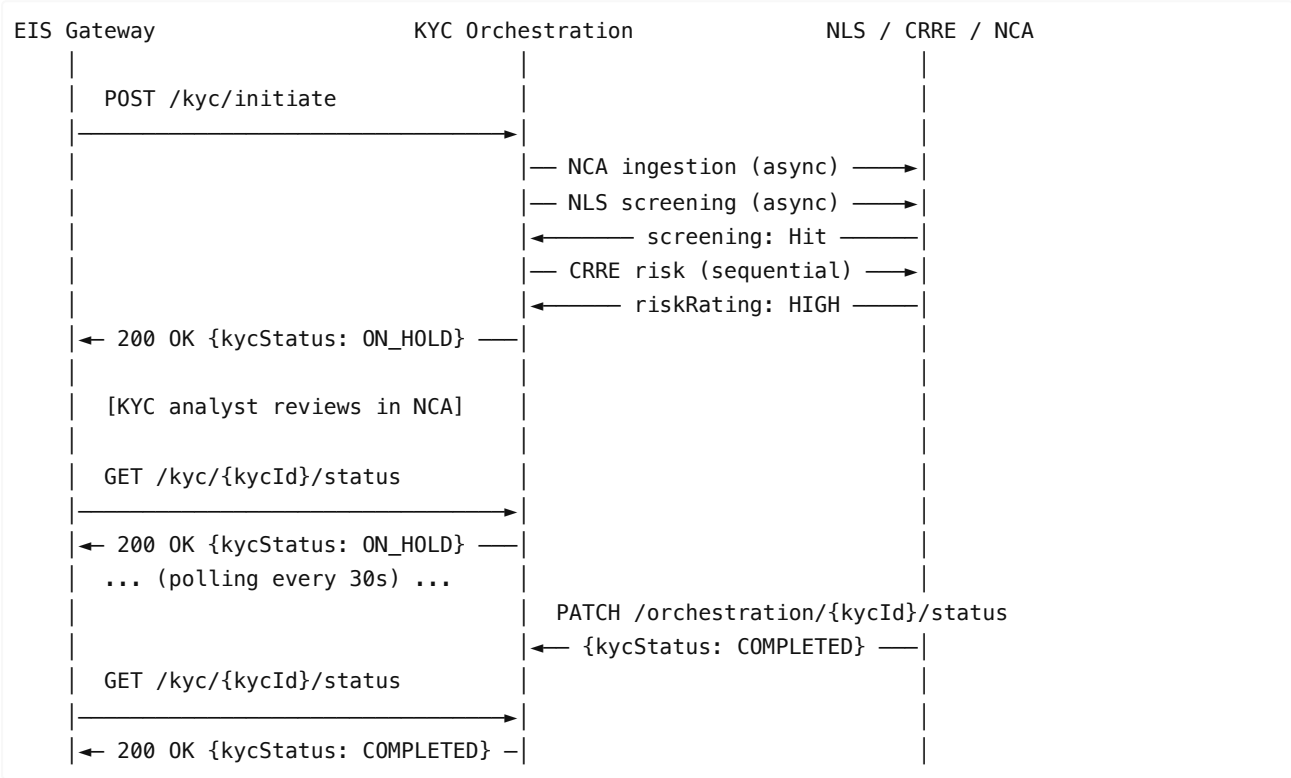
7. End-to-End Flows

Flow A — Clean Pass (No Webhook)

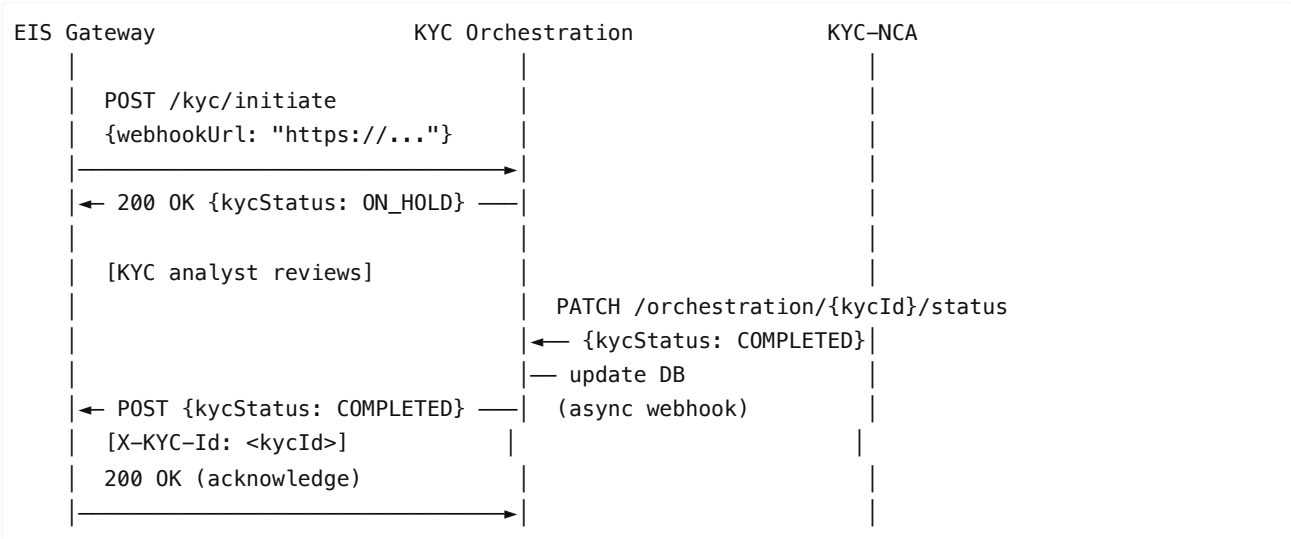




Flow B — On Hold + Polling



Flow C — On Hold + Webhook



8. Architecture & Security Notes

kycId Design

`kycId` values are opaque, non-sequential identifiers generated using the [Hashids](#) library. Internally they encode the database row sequence number, but the encoding is one-way without the server-side salt. This design provides:

Property	Detail
Non-guessable	A salt secret to the service makes enumeration infeasible
No volume leakage	Unlike a raw auto-increment, the encoded string reveals nothing about record count
Reversible internally	The service can decode <code>kycId</code> → DB id without storing a separate mapping column
Single identifier	Consumers receive exactly one identifier; no separate UUID or internal id is ever exposed

Treat `kycId` as an opaque string — do not attempt to parse, decode, or derive meaning from its characters.

PII Encryption

The following fields are stored **AES-128/GCM encrypted** in the database, encrypted and decrypted transparently by a JPA `AttributeConverter` :

Field	Notes
<code>firstName</code>	12-byte random IV per write; IV stored alongside ciphertext (Base64-encoded)
<code>lastName</code>	Same as above
<code>dob</code>	Same as above

The encryption key is supplied via the `encryption.secret-key` property (must be exactly 16 bytes). In production this must come from a secrets manager or environment variable — **never commit the real key**.

CRRE Risk Input Mapping

The following fields from the initiation request are forwarded to CRRE as risk inputs when KYC Orchestration builds the `CalculateRiskRequest` :

Initiation field	CRRE mapping	Location in risk request
<code>clientAdoptionCountry</code>	<code>clientDetails.clientAdoptionCountry</code>	<code>ClientDetails</code>
<code>countryOfDomicile</code>	<code>clientDetails.countryOfDomicile</code>	<code>ClientDetails</code>
<code>investorVisa</code>	<code>clientDetails.investorVisa</code>	<code>ClientDetails</code>
<code>residentialAddress.validFrom</code>	<code>geoRiskType.residentialAddressValidFrom</code>	<code>GeoRiskType</code>

These fields are optional. When absent they are forwarded as `null` and CRRE applies its default scoring logic.

On-Hold Decision Logic

A KYC record is placed `ON_HOLD` when **either** of the following is true at initiation time:

Condition	Source
<code>screeningResult == "Hit"</code>	NLS/NRTS screening service
<code>riskRating == "HIGH"</code>	CRRE risk rating service

Note on `UNKNOWN` risk: A `UNKNOWN` risk rating (returned when CRRE is unavailable or returns unparseable data) does **not** automatically trigger `ON_HOLD` . Consumers receiving `kycStatus=APPROVED` with `riskRating=UNKNOWN`

should apply their own risk policy (e.g. escalate to enhanced due diligence).

Webhook Security

- KYC Orchestration sends webhooks to the URL supplied verbatim in the initiation request. Validate that the URL belongs to your own infrastructure before supplying it.
- Use the `X-KYC-Id` header on incoming webhook calls to deduplicate. Deliver a `2xx` immediately and process asynchronously.
- Retries use exponential back-off (1 s, 2 s, 4 s). After 3 failed attempts the event is dead-lettered to the KYC Orchestration error log. Contact the KYC Platform team for redelivery.

Configuration Properties

Property	Default	Description
<code>server.port</code>	8086	HTTP listener port
<code>hashids.salt</code>	<i>(required)</i>	Secret salt for kycId encoding. Override via <code>HASHIDS_SALT</code> env var.
<code>hashids.min-length</code>	8	Minimum encoded kycId length
<code>encryption.secret-key</code>	<i>(required)</i>	AES-128 key (exactly 16 bytes). Override via <code>ENCRYPTION_SECRET_KEY</code> env var.
<code>eureka.client.serviceUrl.defaultZone</code>	<code>http://localhost:8761/eureka/</code>	Eureka server location

Production checklist:

- ☐ Set `HASHIDS_SALT` to a cryptographically random string (≥ 32 characters)
- ☐ Set `ENCRYPTION_SECRET_KEY` to a 16-byte secret from your secrets manager
- ☐ Disable H2 console (`spring.h2.console.enabled=false`)
- ☐ Replace H2 datasource with a production RDBMS